

Charte de Conformite RGPD

Projet Alumni CRM - Version complete et fidele au code source

1. Contexte Juridique

Le principal defi juridique d'un annuaire d'anciens reside dans le respect strict des donnees personnelles. Le CRM integre une tracabilite native et inalterable via la table CONSENTEMENT_RGPD, conforme au Reglement (UE) 2016/679 (RGPD) et a la loi Informatique et Libertes.

2. Les 4 Types de Consentement Implements

Le systeme differencie quatre categories precises de consentement, chacune etant gerée independamment via des toggles dedies dans l'interface alumni (AlumniConsent.jsx).

Type (Backend)	Cle Frontend	Description
prise_de_contact	contact_allowed	Autoriser l'ecole et les partenaires a contacter l'alumni pour des opportunités professionnelles, des evenements ou des enquetes.
partage_donnees	data_sharing	Autoriser le partage anonymise de donnees statistiques (secteur, poste) avec les entreprises partenaires.
enquetes	survey_participation	Accepter de recevoir et de repondre aux enquetes alumni sur l'evolution professionnelle et la satisfaction.
newsletter	newsletter	Recevoir la newsletter alumni avec les actualites, evenements et offres d'emploi.

3. Mecanisme de Gestion du Consentement

3.1 Collecte du consentement

- Canal principal : formulaire d'inscription Web (AlumniRegistration.jsx).
- Canal secondaire prevu : questionnaire annuel (AlumniSurvey.jsx) ; a ce jour seul le canal 'web' est reellement emis par le frontend.
- Chaque consentement est enregistre avec : type_consentement, statut (actif/refuse), date_consentement, canal, id_etudiant.
- L'endpoint POST /consentements/ cree ou met a jour le consentement pour chaque type.

3.2 Modification et retrait

- L'alumni peut modifier ses preferences a tout moment via l'interface de consentement.
- Le retrait du consentement est modelise par un nouveau vote 'refuse' avec la date courante.
- L'interface affiche la date de derniere mise a jour du consentement.

3.3 Traçabilité

- Enregistrement de la date exacte du recueil (date_consentement).
- Identification formelle du canal de collecte (formulaire inscription, questionnaire).
- Historique complet des votes de consentement dans la base de donnees.

4. Droits RGPD Implementes dans l'Interface

L'interface alumni affiche et implemente les droits suivants :

- Droit d'accès à vos données personnelles : page de profil en lecture seule, suivi des demandes via GET /rgpd/demandes/moi et export Excel auto-service via GET /rgpd/export.
- Droit de rectification et de mise à jour (AlumniProfile.jsx, AlumniProfileUpdate.jsx).
- Droit à l'effacement (droit à l'oubli) : mentionné dans l'interface, implementé via un workflow de demandes auto-service (POST /rgpd/demandes) traité par anonymisation puis purge différée.
- Droit de retrait du consentement à tout moment (AlumniConsent.jsx avec toggles).

5. Modele de Donnees CONSENTEMENT_RGPD

Champ	Type	Contraintes
id_etudiant	Entier (FK)	NOT NULL, reference vers ETUDIANT.id_etudiant.
type_consentement	Enum / Chaîne	Valeurs : 'prise_de_contact', 'partage_donnees', 'enquetes', 'newsletter'.
date_consentement	Date	NOT NULL, date du jour au moment de l'operation.
statut	Chaîne	Valeurs : 'actif' (consentement accorde), 'refuse' (consentement refuse ou retire).
canal	Chaîne	Origine : 'web' (formulaire inscription), 'questionnaire' (enquête annuelle, valeur acceptée par l'API mais non encore émise par le frontend à ce jour).

6. Manques identifiés et correctifs appliqués

Comparaison entre le PDF initial et l'implémentation réelle :

- Le statut 'revoque' mentionné dans le PDF initial n'existe pas dans le code. Seuls 'actif' et 'refuse' sont implémentés.
- Aucun mécanisme de chiffrement spécifique des données de consentement n'est mentionné dans le code (confié au backend/infrastructure).
- CORRIGE : La durée de conservation des données est maintenant affichée dans AlumniConsent.jsx (6 mois après anonymisation).
- CORRIGE : Un contact DPO (dpo@ionis-stm.com) est maintenant affiché dans AlumniConsent.jsx.
- Pas de mécanisme de notification de violation de données dans le frontend.
- PRECISION : une suppression physique d'un consentement est désormais possible via DELETE /consentements/{id_consentement} (propriétaire ou admin) ; le retrait usuel reste modélisé par un nouveau vote 'refuse' afin de préserver l'historique.

7. Workflow des Demandes RGPD (Effacement et Portabilité)

Au-delà du consentement, le CRM met en œuvre un workflow complet de traitement des droits d'accès, d'effacement et de portabilité, basé sur la table DEMANDE_RGPD :

- Depot auto-service : POST /rgpd/demandes (types 'export' ou 'suppression') ; suivi et annulation par l'alumni via GET /rgpd/demandes/moi et DELETE /rgpd/demandes/{id}.

- Cycle de statuts : envoyee -> en_traitement -> traitee/rejetee (contrainte SQL, migration 010), avec verrou anti-traitement parallele (prise_en_charge_par, date_prise_en_charge).
- Traitement d'une demande de suppression = anonymisation irreversible (email remplace par ANONYMISE_<id>@anonymise.io, donnees personnelles effacees), puis purge physique differee apres PURGE_DELAY_MONTHS mois (defaut 6) via purge.py (--dry-run disponible) ou POST /admin/demandes-rgpd/purge-anonymises.
- Portabilite : export Excel auto-service via GET /rgpd/export ; exports admin unitaires et en masse.
- Operations tracees dans AUDIT_LOG (acteur, action, details).